

МОДЕЛИРОВАНИЕ УГРОЗ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ БИОМЕТРИЧЕСКИХ СИСТЕМ РАСПОЗНАВАНИЯ ЛИЦ С ПРИМЕНЕНИЕМ STRIDE, PASTA И MITRE ATT&CK

Ю.В. Тимиршяхова, Р.В. Мещеряков

В условиях постоянного роста числа и сложности кибератак вопросы обеспечения информационной безопасности приобретают особую значимость. Одним из ключевых инструментов в противодействии угрозам является моделирование угроз — системный подход, позволяющий выявлять, классифицировать и анализировать потенциальные риски. Наибольшее распространение получили методики STRIDE, PASTA и MITRE ATT&CK, каждая из которых предлагает уникальные принципы анализа и структурирования угроз. Настоящее исследование представляет обзор этих моделей, анализ их особенностей, преимуществ и ограничений, а также оценивает их применимость в контексте биометрических систем распознавания лиц. Цель работы — провести сравнительный анализ указанных методик и определить их эффективность в формировании комплексной стратегии защиты информационных систем.

Ключевые слова: информационная безопасность, модель угроз, биометрическая система, анализ рисков.

Введение

Современные информационные системы всё чаще подвергаются атакам со стороны злоумышленников, и в условиях цифровизации экономики обеспечение кибербезопасности становится критически важной задачей. Ежегодно фиксируется значительный рост числа атак на государственные и коммерческие организации, причём методы воздействия становятся всё более изощрёнными. Особую значимость защита информации приобретает в биометрических системах, таких как системы распознавания лиц, где нарушение конфиденциальности может привести к необратимым последствиям. В отличие от паролей или токенов, биометрические данные невозможно изменить в случае их компрометации, что делает анализ угроз и построение устойчивых архитектур защиты особенно важными.

Существуют разные модели и методологии моделирования угроз. Среди них три подхода получили наибольшее распространение в научной и практической среде: STRIDE, MITRE ATT&CK и PASTA.

Модель STRIDE была предложена в 1999 году специалистами Microsoft — Л. Конфелдером и П. Гаргом — в качестве

структурированного метода для классификации угроз на этапе проектирования архитектуры информационной системы. Аббревиатура STRIDE образована от первых букв шести категорий угроз: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege [1].

Модель MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) была разработана некоммерческой организацией MITRE в 2013 году. Она представляет собой постоянно обновляемую базу знаний о тактиках и техниках, используемых злоумышленниками. Основная идея модели — систематизация практических сценариев атак, зафиксированных в реальных условиях, с указанием конкретных шагов атакующих и их целей [2].

Методология PASTA (Process for Attack Simulation and Threat Analysis) была предложена в 2015 году специалистами компании VerSprite — Тони Уседа-Вэлезом (CEO) и Марко Мораной (эксперт по безопасности приложений). В отличие от других методологий, PASTA имеет ярко выраженный риск-ориентированный характер: она интегрирует бизнес-контекст, архитектурный анализ и моделирование атак,

проходя через семь этапов — от определения бизнес-целей до оценки возможного ущерба [3].

Цель исследования — провести сравнительный анализ моделей угроз STRIDE, MITRE ATT&CK и PASTA с акцентом на их применимость к биометрическим системам распознавания лиц. В ходе анализа планируется выявить сильные стороны и ограничения каждой из моделей. Полученные результаты будут использованы в дальнейшем для разработки собственной методики, которая позволит устранить выявленные недостатки существующих моделей и обеспечить более точный и адаптированный процесс анализа угроз в области биометрических систем.

1. Моделирование угроз в информационной безопасности

Моделирование угроз является одним из ключевых направлений в построении систем защиты информации. Под данным процессом понимается систематическая идентификация, описание и анализ потенциальных атак, которым может подвергаться информационная система, с последующей оценкой их вероятности и последствий [4,5]. Основная цель моделирования угроз заключается в том, чтобы выявить уязвимые места системы ещё на этапе проектирования или эксплуатации, определить возможные векторы атак, а затем выработать меры по их предотвращению и минимизации ущерба.

Традиционно процесс моделирования угроз включает несколько последовательных шагов. Сначала определяется граница системы, то есть устанавливаются её компоненты, точки взаимодействия с внешними субъектами и каналы передачи информации. После этого проводится идентификация возможных злоумышленников, их мотивации и ресурсов. Затем формируются гипотезы о потенциальных сценариях атак, которые могут быть направлены на нарушение конфиденциальности, целостности и доступности данных. На заключительном этапе угрозы ранжируются по степени критичности, и для наиболее значимых

разрабатываются конкретные меры противодействия [6].

Особую значимость моделирование угроз приобретает в биометрических системах, в частности в системах распознавания лиц. В отличие от традиционных механизмов аутентификации, где при компрометации пароля или токена можно сменить секрет, биометрические данные являются уникальными и неизменяемыми для каждого человека. Как подчёркивают Фомина и коллеги [7], если шаблон лица или отпечатка пальца окажется в распоряжении злоумышленника, восстановить надёжность системы будет крайне сложно. Это обстоятельство делает биометрические системы особенно уязвимыми и требует повышенного внимания к вопросам их безопасности.

На практике для биометрических систем можно выделить несколько ключевых категорий угроз. Наиболее очевидной является угроза подмены личности, когда злоумышленник пытается обойти систему, используя фотографию, видеозапись или специализированные маски, имитирующие лицо зарегистрированного пользователя. Не менее важна угроза компрометации биометрических шаблонов: если база данных с такими шаблонами будет украдена или изменена, это приведёт к массовым нарушениям конфиденциальности и потере доверия к системе. Существенную опасность представляет утечка биометрических данных через инсайдеров или в результате атак на инфраструктуру хранения. Ещё одна категория связана с атаками типа «отказ в обслуживании», когда злоумышленники выводят систему из строя, блокируя доступ пользователей к сервисам. Наконец, особое внимание заслуживает угроза неправомерного повышения привилегий, при которой злоумышленник получает доступ к административным функциям системы и получает возможность изменять её конфигурацию или управлять данными.

Таким образом, моделирование угроз является важнейшим инструментом обеспечения безопасности информационных систем. Оно позволяет не только выявить потенциальные уязвимости, но и соотнести их с реальными сценариями атак и бизнес-

целями организации. В последующих разделах статьи будут рассмотрены три наиболее известные модели угроз — STRIDE, MITRE ATT&CK и PASTA, каждая из которых имеет определённые преимущества и недостатки при применении в контексте биометрических систем распознавания лиц.

2. Обзор моделей угроз

В этом разделе даётся обзор трёх ключевых подходов к моделированию угроз: PASTA (Process for Attack Simulation and Threat Analysis), STRIDE (классическая классификация угроз от Microsoft) и MITRE ATT&CK (база знаний тактик и техник) — с анализом их преимуществ и недостатков применительно к биометрическим системам распознавания лиц. В конце рассматриваются общие ограничения этих методик с учётом особенностей биометрических технологий.

2.1. Модель PASTA

Методология PASTA (Process for Attack Simulation and Threat Analysis) была предложена в 2015 году компанией VerSprite и представляет собой процессный подход к моделированию угроз, ориентированный на бизнес-цели. PASTA представляет собой семиступенчатую методологию:

1. Определение целей. Первый этап направлен на согласование задач по обеспечению безопасности с целями бизнеса. На этом шаге формируются основные ориентиры для всей модели угроз — определяется, что важно для компании и что нужно защитить в первую очередь.

2. Техническое описание системы. Этап технического описания включает в себя определение компонентов системы, архитектуры, потоков данных и границ, чтобы получить полное представление о технической среде. Этот этап очень важен для того чтобы не упустить ничего важного при моделировании угроз.

3. Разработка архитектуры приложения. На этом этапе важно разобраться, как устроено приложение изнутри. Оно делится на части (модули, базы данных, каналы связи), чтобы понять как всё работает. Анализируются потоки данных и

меры защиты. Это помогает найти слабые места и подготовиться к выявлению угроз.

4. Анализ угроз. На этом этапе определяют, какие угрозы могут использовать уязвимости системы. Применяются такие методы, как мозговой штурм, OWASP и деревья атак. Изучаются возможные нападающие, их цели и способы атаки. Это помогает понять, кто может атаковать систему и как, чтобы заранее подготовить защиту.

5. Анализ уязвимости. На этом этапе ищут слабые места в системе, которые могут использовать злоумышленники. Применяются такие методы, как сканирование уязвимостей, анализ кода и тесты на взлом. Затем уязвимости связываются с угрозами и оценивается, насколько они опасны.

6. Моделирование атак. На этом этапе моделируют возможные атаки, чтобы понять, как может действовать злоумышленник. Используют сценарии, имитацию атак и проверку защиты. Это помогает увидеть, какие пути атаки наиболее опасны и насколько система готова к ним.

7. Анализ воздействия и оценка рисков. На последнем этапе оценивают, насколько опасны найденные угрозы и уязвимости. Считают возможный ущерб и вероятность атак, чтобы понять, какие риски самые важные. Это помогает определить, куда направить ресурсы для защиты и какие меры принять в первую очередь. [3].

Такой процесс направлен на то, чтобы соотнести возможные векторы атак с критичностью защищаемых активов и бизнес-последствиями их компрометации

Для биометрических систем PASTA даёт несколько важных преимуществ. Во-первых, методология позволяет формализовать связь между защитой биометрических шаблонов (активом высокой ценности) и потенциальными бизнес-последствиями их утечки или подмены: репутационные риски, правовые издержки по защите персональных данных и длительные репутационные потери при невозможности «сменить» биометрический шаблон. Во-вторых, PASTA ориентирована на моделирование конкретных сценариев атак, поэтому её можно использовать для проработки

сложных цепочек: от компрометации учётной записи администратора (Initial Access) до эксфильтрации шаблонов через каналы резервного копирования. Наконец, PASTA способствует расстановке приоритетов — какие контрмеры первоочередны с точки зрения бизнеса (шифрование хранилищ, защита каналов, механизмы anti-spoofing и т. п.).

Однако PASTA имеет ограничения, которые особенно проявляются в задачах защиты биометрии. Методология требовательна к ресурсам: она предполагает участие экспертов по бизнесу, архитекторам, аналитикам по безопасности и пентестерам, а это делает её дорогостоящей и длительной в исполнении. Для небольших проектов данный подход может оказаться слишком затратным и избыточным. Кроме того, методология не имеет строгой формализации, что приводит к различиям в её интерпретации и затрудняет сопоставимость результатов.

В результате PASTA можно рассматривать как методологию, ориентированную на построение зрелых систем управления рисками. Она особенно ценна в случаях, когда требуется учёт не только технических, но и бизнес-аспектов безопасности, однако требует значительных ресурсов для внедрения и сопровождения.

2.2. Модель STRIDE

Модель STRIDE была разработана корпорацией Microsoft в 1999 году и на протяжении многих лет применяется в качестве основы для построения систем защиты. Она получила название по первым буквам шести категорий угроз: Spoofing (подмена), Tampering (модификация), Repudiation (отказ от авторства действий), Information Disclosure (разглашение информации), Denial of Service (отказ в обслуживании) и Elevation of Privilege (повышение привилегий). Каждая из этих категорий описывает определённый класс атак, которые могут быть реализованы в информационных системах. [1].

Главным достоинством STRIDE является её простота и универсальность. Модель позволяет систематизировать угрозы уже на стадии проектирования архитектуры

системы, а также использовать её на различных этапах жизненного цикла программного обеспечения. Разработчики могут визуализировать архитектуру в виде диаграмм потоков данных, а затем последовательно анализировать каждый элемент, сопоставляя его с шестью категориями угроз. Таким образом достигается полнота анализа и минимизируется вероятность пропуска уязвимостей.

В контексте биометрических систем STRIDE быстро выявляет ключевые классы рисков. Категория Spoofing напрямую отображает проблему обхода распознавания лиц (фото, видео, 3D-маски, replay-атаки), Tampering — риски изменения шаблонов в хранилищах и вмешательства в алгоритмы сравнения, Information Disclosure — перехват и утечка шаблонов при передаче между сенсором и сервером, DoS — перегрузка сервисов распознавания (в т. ч. через массовые запросы) и Elevation of Privilege — получение злоумышленником административных прав, позволяющее массово заменять шаблоны или отключать защитные модули. STRIDE помогает систематично пройти по компонентам архитектуры и зафиксировать «чего бояться» на ранних этапах проектирования. [8].

Однако данная методика обладает и существенными ограничениями. Во-первых, STRIDE носит достаточно абстрактный характер: она лишь классифицирует угрозы, но не указывает, каким образом конкретный злоумышленник будет действовать в реальных условиях. Во-вторых, модель не предусматривает ранжирования угроз по степени их опасности, что осложняет приоритизацию защитных мер — эту работу приходится выполнять дополнительно, часто в связке с PASTA или другими схемами оценки рисков. [9]. В-третьих, STRIDE недостаточно учитывает организационный контекст и человеческий фактор, сосредотачиваясь преимущественно на архитектуре и технических аспектах. В-четвертых, STRIDE не отражает временную динамику атак и цепочки действий злоумышленника (как одна компрометация ведёт к следующей).

Таким образом, STRIDE является удобным инструментом для начальной классификации угроз, однако её применение требует дополнения другими методологиями, которые позволяют моделировать конкретные сценарии атак и учитывать их последствия для бизнеса.

2.3. Модель MITRE ATT&CK

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) представляет собой обширную базу знаний о тактиках, техниках и процедурах злоумышленников. Она была создана организацией MITRE в 2013 году и стала одной из наиболее популярных методик анализа угроз в последние годы. В отличие от STRIDE, которая носит классификационный характер, MITRE ATT&CK строится на эмпирических данных: в основу положены реальные примеры атак, зафиксированные специалистами в различных областях.

Ключевая особенность MITRE ATT&CK заключается в её структуре, которая представлена в виде матрицы. В строках матрицы указываются тактики — высокоуровневые цели злоумышленников, такие как первоначальный доступ, выполнение кода, закрепление в системе, повышение привилегий, уклонение от обнаружения, кража данных или их эксфильтрация. В столбцах перечислены техники, то есть конкретные способы достижения этих целей, например использование фишинговых писем, эксплуатация уязвимостей программного обеспечения, внедрение вредоносных скриптов или атаки через поставщиков. Для каждой техники даётся подробное описание, примеры её применения, а также возможные методы защиты и обнаружения. [2].

Преимуществами MITRE ATT&CK являются высокая степень детализации, практическая направленность и регулярное обновление. Кроме того, данная методика позволяет организациям сопоставлять собственные возможности защиты

с актуальными сценариями атак и выявлять пробелы в системе безопасности.

Что касается вопросов биометрии, то очевидно, что это источник конкретных техник атак (например, методы получения учётных данных, эксплуатация уязвимостей, эксфильтрация файлов), которые можно сопоставить с реальными компонентами биометрической системы (серверы, базы шаблонов, рабочие станции администраторов). Используя ATT&CK, команда безопасности может строить карту возможных атак и настраивать средства детекции (логирование, поведенческий анализ), опираясь на реальные примеры. Особенно полезно это при подготовке планов реагирования и тестирования (red-team/blue-team). [10].

Тем не менее, MITRE ATT&CK не лишена недостатков. Её использование требует высокой квалификации специалистов и значительных аналитических ресурсов, так как необходимо интерпретировать большое количество данных и адаптировать их под конкретную систему. Кроме того, в базе знаний могут присутствовать временные задержки в отражении новых угроз, что снижает её эффективность в условиях быстро меняющегося ландшафта кибератак. Наконец, MITRE ATT&CK не всегда легко адаптируется к узкоспециализированным системам, где применяются специфические методы защиты и атаки.

В контексте биометрических систем: ограничения MITRE ATT&CK связаны с тем, что база в основном описывает «классические» ИТ-тактики и техники и не даёт специализированных приёмов для атак, уникальных для систем распознавания на основе нейросетей (например, механики генеративных атак против извлечения признаков или способы «заглаживания» способности алгоритма отличать real vs. fake). Кроме того, полноценное применение ATT&CK требует развитой инфраструктуры мониторинга и компетенций по анализу событий, что не всегда доступно малым и средним организациям.

3. Сравнительный анализ моделей STRIDE, MITRE ATT&CK и PASTA

Проведённый обзор показал, что три рассмотренные методики — STRIDE, MITRE ATT&CK и PASTA — имеют различное происхождение, преследуют разные цели и опираются на разные принципы анализа угроз. Это определяет их сильные стороны и ограничения, а также обуславливает возможность их комбинированного применения.

Прежде всего, модели отличаются уровнем абстракции и детализации. STRIDE представляет собой наиболее общую классификацию угроз, которая даёт возможность систематизировать возможные векторы атак, но при этом не предполагает анализа конкретных сценариев. Она удобна на этапе проектирования архитектуры системы, так как позволяет выявить слабые места в логике взаимодействия компонентов. В биометрических системах STRIDE полезна, например, для того чтобы на уровне диаграмм потоков данных выявить угрозы подмены личности или раскрытия информации при передаче биометрических шаблонов между клиентским устройством и сервером. Однако при применении STRIDE невозможно глубоко оценить, каким образом злоумышленник сможет реализовать атаку на систему и какие инструменты при этом будут использоваться.

MITRE ATT&CK, напротив, является максимально приближённой к практике и основанной на эмпирических данных моделью. Она структурирует реальные техники и тактики злоумышленников, что позволяет организациям сопоставлять свои защитные механизмы с существующими сценариями атак. В отличие от STRIDE, MITRE ATT&CK не ограничивается теоретической классификацией, а фактически предоставляет карту действий злоумышленника, начиная от первоначального доступа и заканчивая эксфильтрацией данных. В биометрических системах это особенно важно, так как позволяет не только выявить угрозу компрометации базы шаблонов, но и описать возможные пути её осуществления, включая фишинговые атаки на администраторов,

эксплуатацию уязвимостей серверов или применение методов обхода алгоритмов распознавания. Однако высокая степень детализации делает MITRE ATT&CK сложной в применении: организациям требуется значительный уровень экспертизы и развитая инфраструктура мониторинга для того, чтобы использовать эту базу знаний в повседневной практике.

PASTA занимает промежуточное положение между абстрактной классификацией STRIDE и практической базой MITRE ATT&CK. Её основное отличие заключается в ориентации на бизнес-контекст и управление рисками. В отличие от STRIDE, которая рассматривает угрозы исключительно с технической точки зрения, и MITRE ATT&CK, сосредоточенной на тактиках и техниках атак, PASTA стремится увязать угрозы с целями бизнеса. Таким образом, методология позволяет определить, какие атаки представляют наибольшую опасность не только в техническом, но и в экономическом или репутационном аспекте. В случае с биометрическими системами это особенно важно: компрометация биометрических данных имеет долгосрочные последствия, так как в отличие от паролей они не могут быть изменены. Поэтому PASTA даёт возможность оценить потенциальные риски утечки шаблонов лиц не только как техническую проблему, но и как угрозу стратегическим интересам организации, её репутации и правовому положению. Вместе с тем сложность методологии и потребность в значительных ресурсах ограничивают её использование в небольших проектах.

Сравнение моделей по ряду критериев показывает, что STRIDE выигрывает в простоте и универсальности, но проигрывает в практической применимости. MITRE ATT&CK превосходит STRIDE в детализации и приближённости к реальным сценариям, однако требует высокой квалификации специалистов. PASTA же демонстрирует наибольшую полноту анализа, учитывая как технический, так и бизнес-контекст, но обладает высокой трудоёмкостью внедрения.

Если рассматривать биометрические системы, каждая из моделей покрывает

разные аспекты анализа угроз. STRIDE позволяет выявить базовые категории атак на архитектурном уровне, MITRE ATT&CK помогает моделировать конкретные сценарии обхода аутентификации или компрометации базы шаблонов, а PASTA позволяет оценить влияние реализации этих угроз на устойчивость бизнеса и его стратегические интересы. Таким образом, применение всех трёх моделей в комплексе обеспечивает наиболее полное покрытие угроз и позволяет выработать эффективные меры защиты.

4. Практическое значение и комбинированный подход

Анализ трёх моделей угроз — STRIDE, MITRE ATT&CK и PASTA — показывает, что каждая из них обладает уникальными характеристиками и может применяться для решения различных задач информационной безопасности. Однако ни одна из моделей в отдельности не обеспечивает комплексного анализа, охватывающего все этапы жизненного цикла информационной системы и учитывающего как технические, так и организационные аспекты. Это особенно критично в случае биометрических систем, где последствия реализации угроз могут быть необратимыми.

Практическое значение STRIDE заключается в том, что она позволяет формализовать процесс анализа угроз на ранних этапах проектирования. Использование этой модели помогает архитекторам и разработчикам выявлять потенциальные уязвимости ещё до внедрения системы. В биометрических системах STRIDE даёт возможность выявить угрозы подмены личности при захвате изображений, угрозы подмены или утечки шаблонов при хранении данных, а также угрозы отказа в обслуживании при массовом использовании системы. Простота и универсальность модели делают её незаменимым инструментом при первичном анализе архитектуры.

MITRE ATT&CK приобретает особую ценность на этапе эксплуатации и мониторинга систем. В отличие от STRIDE, данная модель содержит описание конкретных техник и тактик злоумышленников, что позволяет

адаптировать средства обнаружения атак под реальные сценарии. Применение ATT&CK в биометрических системах позволяет организациям строить системы обнаружения вторжений, настраивать системы корреляции событий безопасности и тестировать эффективность существующих защитных мер. Например, при моделировании атак на базу биометрических шаблонов можно опираться на конкретные техники MITRE ATT&CK, такие как T1087 (сбор учётных данных), T1059 (исполнение командного интерпретатора) или T1003 (доступ к хэшам и секретам). Таким образом, использование ATT&CK даёт возможность выстроить практико-ориентированную стратегию защиты, опирающуюся на реальные угрозы.

PASTA играет важную роль в стратегическом управлении рисками. В отличие от STRIDE и ATT&CK, она не ограничивается выявлением уязвимостей или описанием сценариев атак, а позволяет увязать угрозы с бизнес-целями организации. Это особенно важно в условиях, когда компрометация биометрических систем может иметь далеко идущие последствия, включая потерю доверия со стороны пользователей, репутационные издержки и юридическую ответственность. Применение PASTA позволяет руководству организаций принимать обоснованные решения о распределении ресурсов на защиту наиболее критичных элементов системы, исходя из оценки вероятности и потенциального ущерба от атак.

Комбинированный подход к использованию моделей STRIDE, MITRE ATT&CK и PASTA обеспечивает наиболее полное покрытие угроз и создаёт условия для построения многоуровневой системы безопасности. На ранних этапах проектирования STRIDE помогает выявить основные классы угроз и встроить механизмы защиты в архитектуру системы. На этапе эксплуатации MITRE ATT&CK позволяет выстраивать процессы мониторинга и реагирования на инциденты, используя реальные сценарии атак. На стратегическом уровне PASTA обеспечивает оценку рисков с точки зрения бизнес-целей и помогает расставлять приоритеты при распределении ресурсов.

Таким образом, практическое значение комбинированного подхода заключается в его универсальности и комплексности. Он позволяет организациям учитывать как технические, так и организационные аспекты угроз, опираясь на преимущества каждой модели. Применение STRIDE, MITRE ATT&CK и PASTA в совокупности обеспечивает устойчивую защиту биометрических систем распознавания лиц, минимизируя вероятность успешных атак и снижая последствия их реализации.

Заключение

В ходе проведённого исследования были рассмотрены три наиболее известные модели угроз — STRIDE, MITRE ATT&CK и PASTA, которые широко применяются в современной практике анализа и управления рисками информационной безопасности. Каждая из этих моделей обладает своими преимуществами и ограничениями, а их использование зависит от задач, стоящих перед специалистами по безопасности, и особенностей конкретной системы.

Модель STRIDE, разработанная в Microsoft, отличается простотой и универсальностью. Она позволяет классифицировать угрозы на архитектурном уровне и выявлять уязвимости на ранних этапах проектирования. В биометрических системах STRIDE может быть использована для анализа угроз подмены личности, компрометации биометрических шаблонов или отказа в обслуживании. Однако STRIDE остаётся достаточно абстрактной и не отражает реальных сценариев атак, что снижает её ценность при практическом применении.

Модель MITRE ATT&CK представляет собой наиболее практико-ориентированный инструмент. Её сила заключается в наличии базы знаний о конкретных техниках и тактиках злоумышленников, подтверждённых реальными кейсами. Применение MITRE ATT&CK в биометрических системах позволяет моделировать реальные сценарии атак, а также выстраивать процессы мониторинга и реагирования на инциденты. Ограничением является высокая сложность модели,

требующая значительной подготовки специалистов, а также не всегда достаточная адаптированность к узкоспециализированным системам.

Модель PASTA ориентирована на риск-ориентированный подход и учитывает бизнес-контекст. Она позволяет не только выявить угрозы и уязвимости, но и соотнести их с потенциальными экономическими и репутационными потерями для организации. В случае биометрических систем PASTA оказывается особенно полезной, так как утечка биометрических данных несёт долгосрочные последствия, которые невозможно устранить простыми техническими средствами. Главным недостатком методологии является её трудоёмкость и необходимость привлечения специалистов высокой квалификации.

Сравнительный анализ показал, что каждая из моделей закрывает разные аспекты обеспечения безопасности. STRIDE даёт возможность формализовать базовые классы угроз, MITRE ATT&CK обеспечивает привязку к реальным сценариям атак, а PASTA позволяет оценить стратегическую значимость рисков. Использование этих моделей в изоляции не обеспечивает полноценного охвата всех аспектов безопасности. Наиболее перспективным представляется их комбинированное применение: STRIDE — на этапе проектирования архитектуры, MITRE ATT&CK — при эксплуатации и мониторинге, PASTA — для стратегического управления рисками.

Научная новизна данного исследования заключается в сопоставлении трёх моделей в контексте применения к биометрическим системам распознавания лиц. Такой подход позволяет комплексно оценить угрозы как на архитектурном, так и на прикладном и стратегическом уровнях. Практическая значимость работы заключается в том, что организациям предлагается универсальный методический подход, основанный на интеграции трёх моделей, что позволяет выработать более устойчивую стратегию защиты.

В дальнейшем целесообразно проводить исследования, направленные на разработку гибридных методологий моделирования

угроз, сочетающих простоту классификации STRIDE, практическую ориентированность MITRE ATT&CK и риск-ориентированный характер PASTA. Особое внимание должно быть уделено адаптации существующих моделей к специфике биометрических систем и учёту человеческого фактора, который остаётся одним из важнейших источников уязвимостей.

Список литературы

1. Угрозы, входящие в средство моделирования угроз (Майкрософт) // Microsoft Learn. 2023. URL: <https://learn.microsoft.com/ru-ru/azure/security/develop/threat-modeling-tool-threats#stride-model> (дата обращения: 01.04.2024).
2. MITRE ATT&CK Navigator // MITRE Corporation. URL: <https://attack.mitre.org/navigator/> (дата обращения: 05.04.2024).
3. Каков процесс моделирования атаки и анализа угроз (PASTA) модели угрозы? // PureStorage. 2023. URL: <https://www.purestorage.com/knowledge/pasta-threat-modeling.html> (дата обращения: 05.04.2024).
4. Чечулин А. А. Моделирование нарушителя, инфраструктуры и атак в системах информационной безопасности /А.А. Чечулин // Вестник Санкт-Петербургского университета ГПС МЧС России. 2024. Вып. № 2. С. 70–79.
5. Теория информационной безопасности и методология защиты информации: учебное пособие / Л.В. Астахова. – Челябинск: Издательский центр ЮУрГУ, 2014. 137 с.
6. Основы информационной безопасности: учебно-практическое пособие /Ю.Н. Сычев/ М.: Изд. центр ЕАОИ, 2007. 300 с.
7. Модели угроз и нарушителей безопасности информации объектов информатизации: учеб. пособие / К.Ю. Фомина [и др.]/ Рязань: Рязанский государственный радиотехнический университет, 2024. 88 с.
8. Титов А. Методология STRIDE в моделировании угроз [Электронный ресурс] // ThreatScope. 2025. Режим доступа: https://threatscope.ru/about-stride/?utm_source (дата обращения: 01.08.2025).
9. Миняев А.А. Моделирование угроз безопасности информации в информационных системах /А.А. Минаев // Научные технологии в космических исследованиях земли Т.13 № 2-2021 С.52-64
10. Москвин А. MITRE ATT&CK: что это и как применять в целях кибербезопасности // Anti-Malware.ru. 2023. URL: https://www.anti-malware.ru/analytics/Technology_Analysis/MITRE-ATT-CK-for-cybersecurity-purposes?utm_source (дата обращения: 01.08.2025).

Институт проблем управления имени В. А. Трапезникова Российской академии наук
Institution of Control Science. V.A. Trapeznikova Russian Academy of Sciences

Поступила в редакцию 25.10.2025

Информация об авторах

Тимиршяхова Юлия Владимировна – аспирант, Институт проблем управления имени В. А. Трапезникова Российской академии наук, e-mail: gyv_yulya@mail.ru
Мещеряков Роман Валерьевич – доктор технических наук, профессор, главный научный сотрудник Института проблем управления им. В. А. Трапезникова РАН, e-mail: mrv@ipu.ru

THREAT MODELING IN BIOMETRIC SYSTEMS: INTEGRATING THE STRIDE, PASTA, AND MITRE ATT&CK METHODOLOGIES

Yu.V. Timirshaiakhova, R.V. Meshcheryakov

In the context of the continuous increase in both the number and complexity of cyberattacks, the issue of ensuring information security is becoming increasingly critical. One of the key tools for countering such threats is threat modeling—a systematic approach that enables the identification, classification, and analysis of potential risks. The STRIDE, PASTA, and MITRE ATT&CK methodologies are among the most widely adopted frameworks, each offering unique principles for analyzing and structuring threats.

This study provides an overview of these models, analyzes their characteristics, advantages, and limitations, and evaluates their applicability within the context of facial recognition biometric systems. The primary objective of the research is to conduct a comparative analysis of the aforementioned methodologies and to determine their effectiveness in developing a comprehensive strategy for protecting information systems.

Keywords: information security, threat models, biometric systems, risk analysis.

Submitted 25.10.2025

Information about the authors

Yulia Vladimirovna Timirshaiakhova – PhD Student, V. A. Trapeznikov Institute of Control Sciences, Russian Academy of Sciences, e-mail gyv_yulya@mail.ru

Roman Valeryevich Meshcheryakov – Dr. Sc. (Technical), Professor, Chief Researcher at the V. A. Trapeznikov Institute of Control Sciences, Russian Academy of Sciences, e-mail mrsv@ipu.ru